Memory optimization for small language model security agents

CISM is an autonomous vulnerability assessment agent driven by a model small enough to run on the operator's own machine.

Madhan T B	23BCE1087
Manikandan S	23BCE1476
Sushindh A	23BCE1513

VELLORE INSTITUTE OF TECHNOLOGY, CHENNAI

17245

16384

tokens sent against the window

The agent's own budget said the request fit. The server disagreed.

THE PROBLEM

The model that keeps your data cannot keep your context.

A hosted model strong enough for this job needs target names, banners, credentials and raw tool output sent to a third party. An engagement contract usually forbids that.

A local model keeps the data. It also runs out of room. One real request overflowed the server's own window by about 1300 tokens while still fitting the agent's estimate.

NODES.PY LINE 52, LIVE ROUND 12

MOTIVATION

A hosted endpoint is unavailable under a contract that forbids egress.

DATA BOUNDARY | EVIDENCE

PROPERTY	ADVISORY ASSISTANT	SHELL DRIVING AGENT	CISM
Runs without sending engagement data off the machine	no	no	yes
Acts autonomously across multiple steps	no	yes	yes
Scope enforced before the process is created	n/a	no	yes

A system that cannot run without a hosted endpoint is unavailable for engagements whose contracts forbid data egress, however well it performs elsewhere.

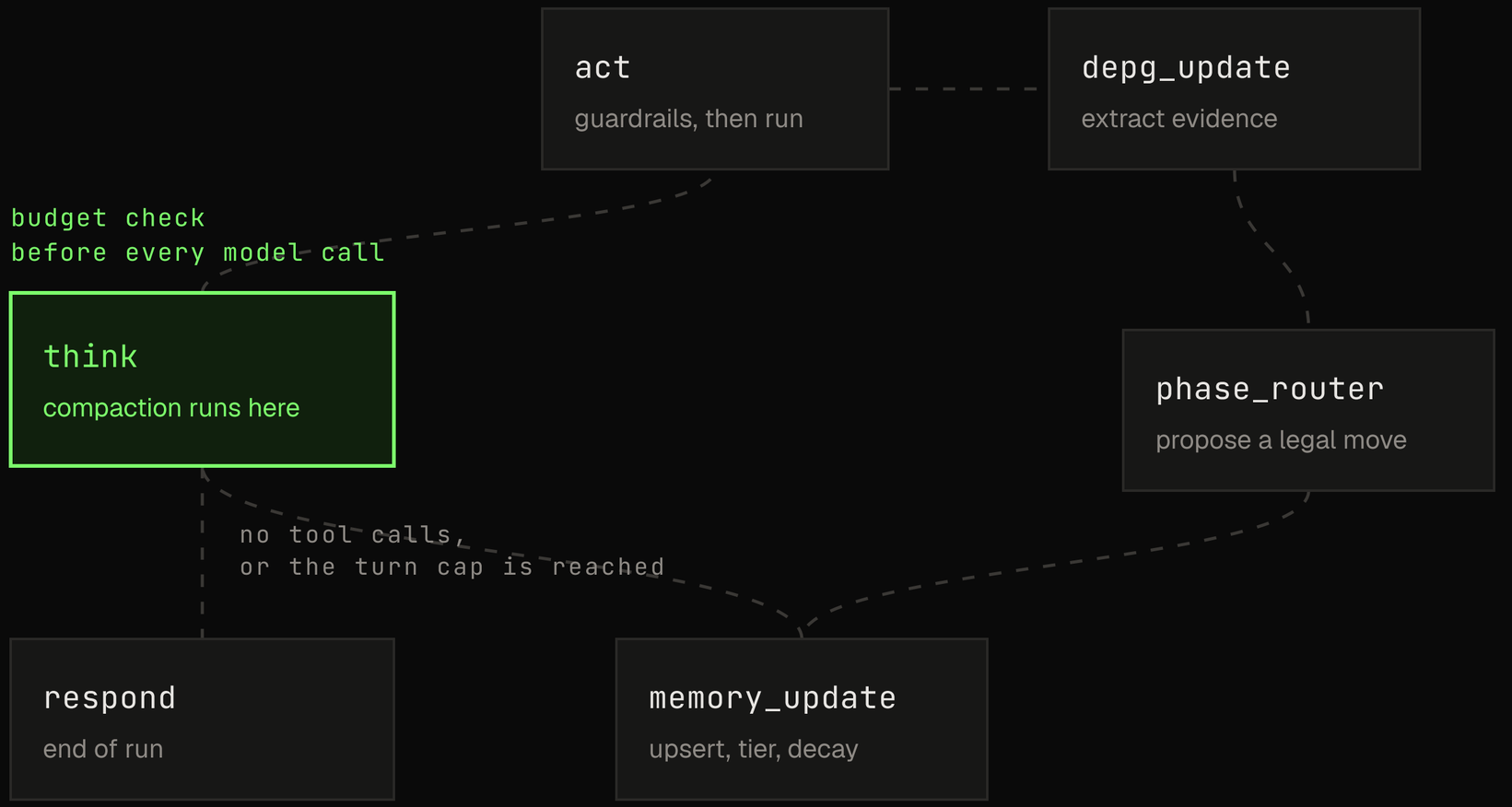
Architecture

01

The model supplies direction. Memory, grounding, phase discipline and pre execution policy come from the system around it.

THE AGENT LOOP

Six nodes, one loop, one budget check.



Click any node.

The agent is a LangGraph state machine with six nodes: think, act, extract, route, remember and respond.

State persists across submissions within one process through a checkpointer.

WHERE COMPACTION TRIGGERS

Compaction runs inside think, before the model is called.

```
_CHARS_PER_TOKEN = 3
_RESPONSE_RESERVE_TOKENS = 512
_PER_MESSAGE_OVERHEAD_TOKENS = 4
DEFAULT_CONTEXT_WINDOW = 32_768

def _compact_history(messages, system_prompt, context_window):
    budget = (context_window
              - _RESPONSE_RESERVE_TOKENS
              - _estimate_tokens(system_prompt))

    kept, dropped = _fit(messages)
    if dropped:
        kept, dropped = _fit(_shrink_old_tool_output(messages))
    if dropped:
        kept, dropped = _fit(_stub_old_tool_output(messages))
    return kept, dropped
```

The budget

No generic local tokenizer exists, so the estimate is 3 characters per token with 4 tokens of overhead per message. 512 tokens stay reserved for the answer.

The window

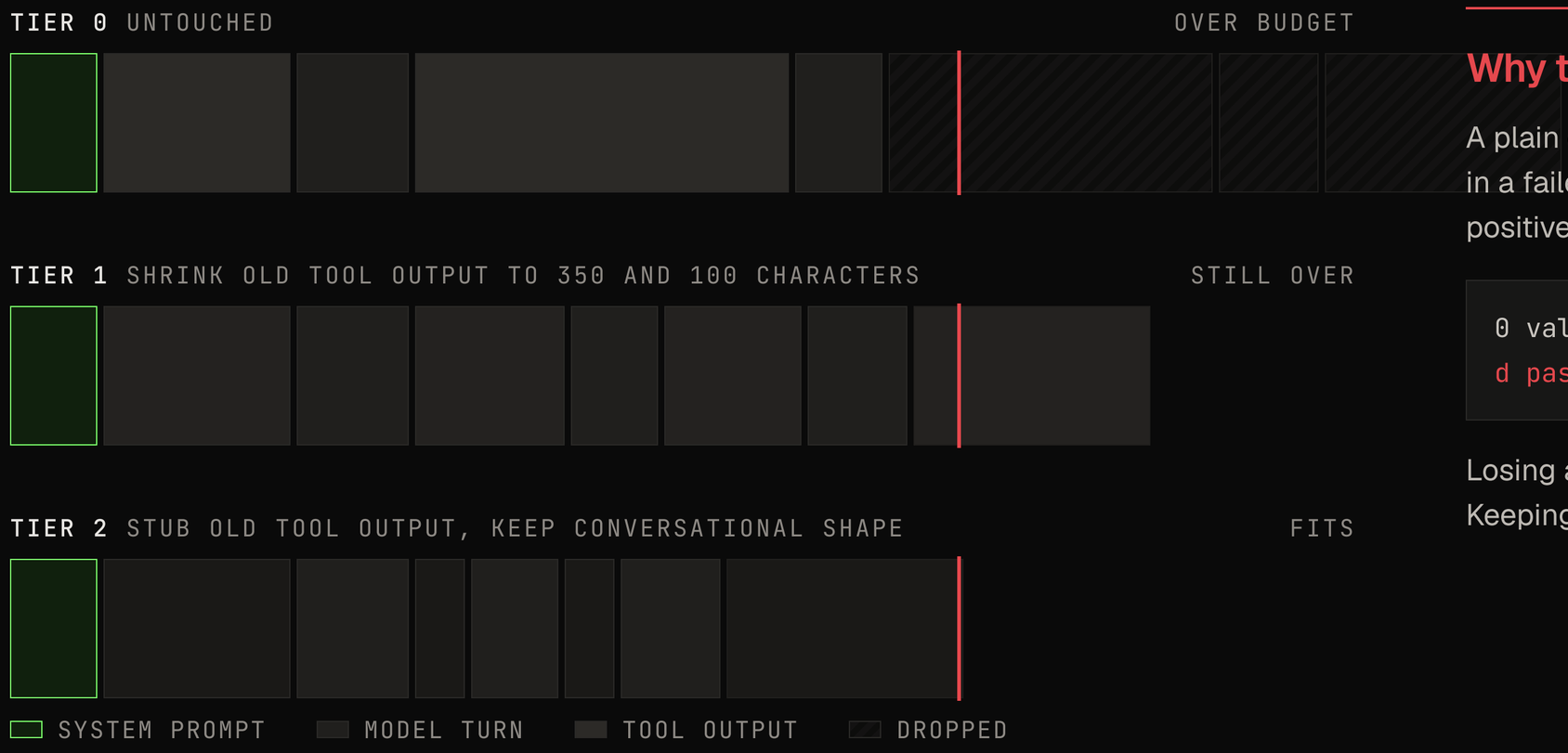
The default window is 32768 tokens. The system prompt is subtracted first, because it is sent on every turn.

The cascade

Each tier runs only when the one before it still did not fit. Full history stays in state. This only shapes what is sent to the model.

THE CASCADE

Three tiers, cheapest sufficient wins.



Why the cut snaps to a word

A plain character cut landed inside the word valid in a failed hydra run. The tail it left read as a positive hit.

```
0 valid password found
d password found
```

Losing a partial word at either edge costs nothing. Keeping half of one can flip what a finding means.

Each tier engages only once the one before it still could not fit the budget.

PHASE LOCK

An illegal phase jump is not reachable.

a jump from recon straight to exploit is refused by transition()



Six phases, one choke point.

Every phase change goes through `PhaseStateMachine.transition()`. Nothing else may move the phase.

Dashed arcs are the legal pivots back. Reporting accepts only itself.

The audit found the router advancing one phase per successful tool call, reaching reporting in about 5 calls. The table is what made that visible.

GUARDRAILS

Nothing spawns before every stage allows it.

01	`ScopeGuardStage`	Blocks a call whose target falls outside the declared engagement scope, a CIDR and domain allowlist.
02	`DangerousFlagGuardStage`	Blocks free form flags that could read or write outside the scratch directory, or trigger code execution.
03	`PhaseToolGuardStage`	Re-checks the tool against the current phase allowlist at call time, not at registration time.
04	`ToolOutputScreenStage`	Screens tool output for prompt injection markers before it is fed back into the model.
05	`OutputRedactionStage`	Redacts credentials and secrets from the final answer the operator sees and exports.

> The catalog fails closed. A tool that writes, executes or destroys is registered but unreachable in every phase until someone adds an explicit phases key.

CONTAINMENT

One argv only seam carries every real tool call.



WHAT THE SEAM GUARANTEES

No shell

Execution is argv only. A quoted string never reaches an interpreter.

No persistence

The per call scratch directory no longer exists once the call returns.

No orphans

A hard timeout kills the whole process tree, not just the leaf.

No arbitrary paths

hydra's wordlist arguments only ever select one of two fixed, named wordlists.

2 GB MEMORY	2 GB SWAP
2 PROCESSORS	512 PROCESSES

Memory

02

A claim the model cannot ground against real tool text is demoted instead of reported.

DEPENDENCY AND ERROR PROPAGATION GRAPH

Every finding carries the output that proves it.



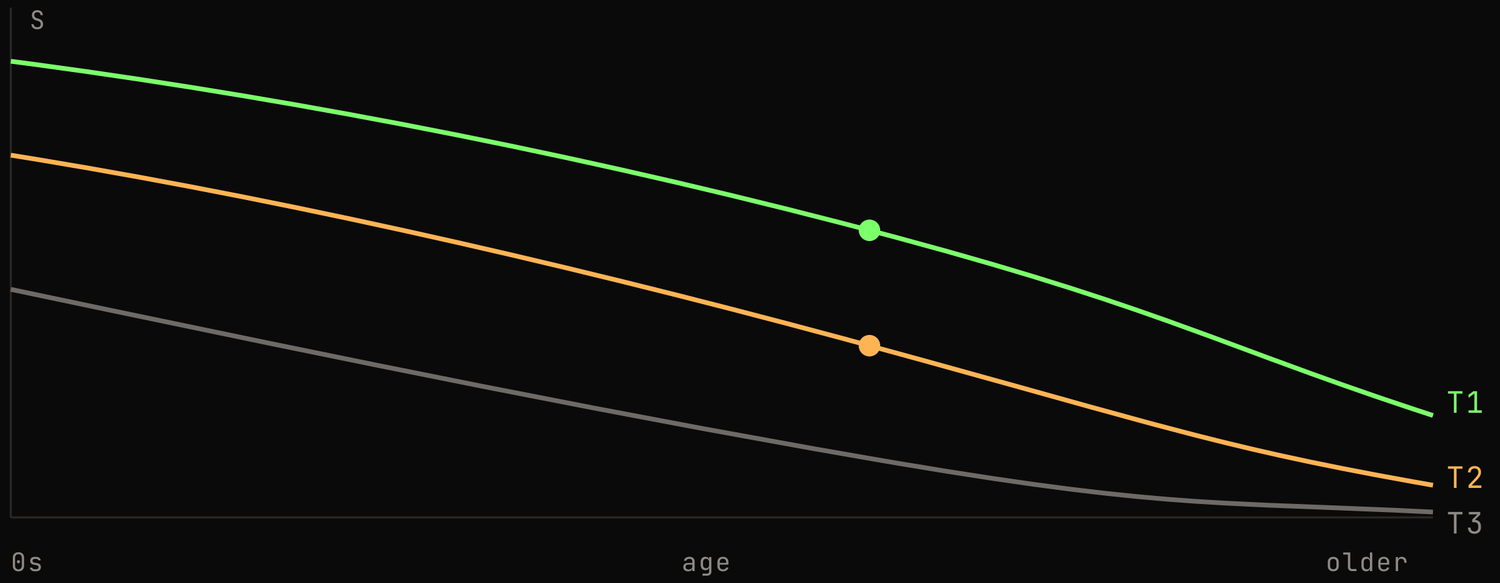
A disproved precondition blocks what depended on it. Pruning then collapses the region that is fully dead, so a wrong early branch does not stay in the operator's view.

Click any node.

The graph merges proposed nodes and edges, resolves each dirty node's state, then prunes fully dead regions.

TIERED MEMORY

Memory decays unless the run keeps hitting it.



Each item carries a tier, the phase it was seen in, a snippet and a salience score.

A recurring narration or tool failure collapses onto one row and increments its hit count instead of filling the view.

Tier weight sets the starting height. The hit bonus is what lifts a row back up.

$$S = w_{tier} \cdot s_0 \cdot e^{(-\lambda \cdot age)} + \beta \cdot hits$$

Results

03

Measured against a containerized Damn Vulnerable Web Application on an isolated bridge network, with its database initialized.

EXPERIMENTAL SETUP

Real target, real tools, real local inference.

TARGET

A containerized Damn Vulnerable Web Application on an isolated bridge network, database initialized, security level left at the image default. Scope is the target address alone.

INFERENCE

A local llama.cpp server hosting a quantized small model, reached over its OpenAI compatible endpoint.

AGENT

Inside the hardened container. All capabilities dropped except the one bubblewrap requires.

INSTRUCTIONS

Three scripted submits covering reconnaissance, enumeration and injection testing.

REPETITIONS

x2

Each configuration run twice.

0 → 8

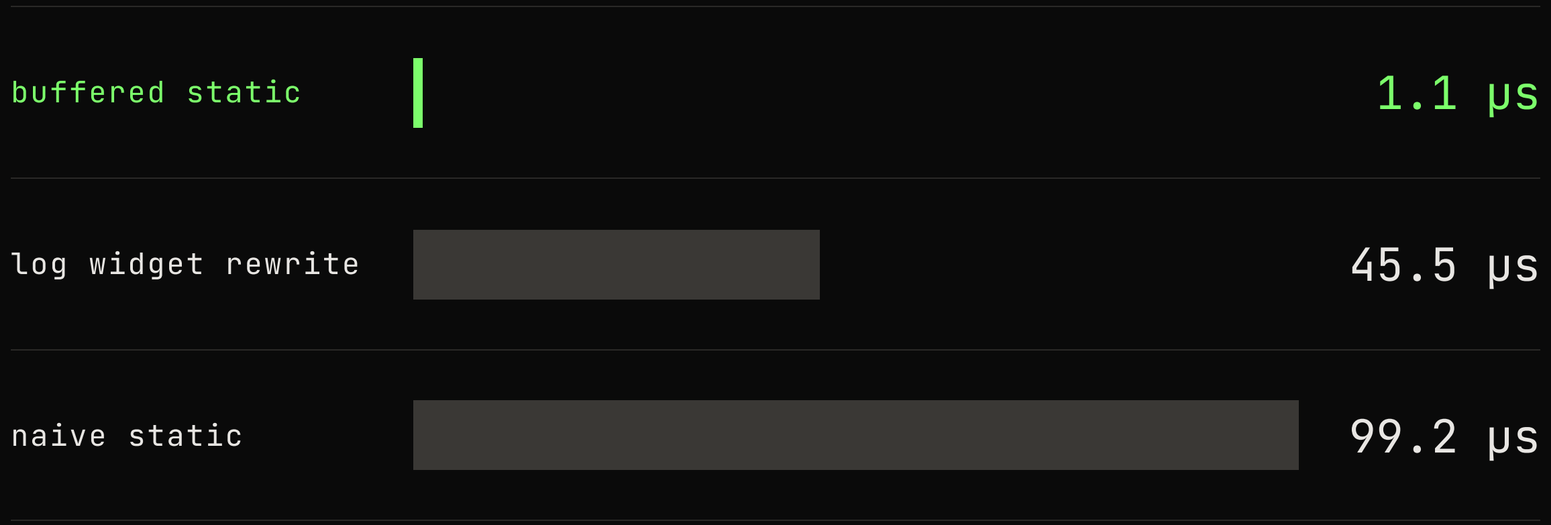
Correcting three extractor defects took one engagement from 0 to 8 evidence backed findings. Same model, same target, same instructions.

TOOL	BEFORE	AFTER	DEFECT
gobuster	0	5	progress escapes defeated the pattern
whatweb	0	2	no extractor existed
wafw00f	0	1	assumed a secure scheme
total	**0**	**8**	**correctness, not a new capability**

All three defects were invisible to a test suite written against clean sample output. All three were visible at once against real output from a real target.

RENDERING BENCHMARK

The shipped transcript stays flat as the entry grows.



The benchmark streams 8000 tokens into one wrapping paragraph in a terminal 100 columns by 30 rows.

The shipped strategy measures 1.4 microseconds at 4000 tokens and 1.1 at 8000. The naive strategy climbs from 58 to 99 over the same range, which is quadratic in entry length.

per token cost / lower is better / bench/stream_bench.py

VALIDATION

786 tests and a harness repeatable to a tenth of a second.

786

automated tests across 53 modules, mirroring the source tree roughly one to one. Ten of them are terminal snapshots that pin the rendered appearance.

53

test modules

6500

lines of code in the audited package, read line by line

HEADLESS HARNESS

RUN 1	RUN 2
2.9 s	3.0 s

time to first finding, 1 finding each

10

snapshot tests pinning the terminal appearance

OBSERVED FAILURE MODES

Three failures we are reporting, not hiding.

FAILURE 01

A tool offering turn answered with a question

The model asks for the target address when that address already sits in the instruction and the system prompt. A bounded retry was implemented and then reverted, because a discarded attempt's tokens leaked into the operator's transcript.

FAILURE 02

A placeholder passed as a real argument

The model invoked the port scanner with the literal placeholder token as the target, producing a real call that failed at name resolution.

FAILURE 03

Silent unavailability under a stalled phase

When an early call produces no finding, the phase never advances past reconnaissance, so a later request for an injection tool cannot be satisfied. The operator received no signal.

> Offline validation against clean sample output is insufficient for this class of system.

LIMITS AND NEXT PHASE

Every limit names the seam it extends into.

WHAT THE WORK DOES NOT CLAIM

Evaluation used a single target application and a single model family.

Checkpointed state does not survive a process restart.

The dangerous argument stage is a denylist, so an unanticipated argument form is permitted by default.

The sandbox shares the host network, so scope is enforced on argv text and not at the operating system boundary.

FUTURE WORK, HIGHEST IMPACT FIRST

- → Make a discarded model attempt invisible to the event stream.
- → Add an argument validation guardrail stage.
- → Replace the denylist with an allowlist grammar per tool.
- → Implement network egress control for the sandbox.

INDIVIDUAL CONTRIBUTION

Three owners, three separable bodies of work.

Madhan T B

23BCE1087

Model inferencing and the context window. The think and act loop in LangGraph. The graph mathematics and its implementation: the reducer, the support policy, settle and prune. Phase locking. The model based extractor backends. Inference benchmarking.

Manikandan S

23BCE1476

The terminal interface. Tool integration across nmap, hydra, gobuster, whatweb and wafw00f plus the offline stubs. The deterministic extractors. Sandboxing with bubblewrap. Guardrail implementation. Lab deployment, the test suite and continuous integration.

Sushindh A

23BCE1513

Model testing for tool call and text fallback reliability across candidate models. Accuracy benchmarking. The ablation study with and without the graph, the phase lock and the guardrails. Prompt quality control. Guardrail red teaming. The literature survey.

The architecture carries the model.

0 to 8

findings from one engagement after three extraction defects were corrected, with no change to the model.

786

automated tests, plus a headless harness repeatable to a tenth of a second.

9

real tools behind one sandboxed, argv only seam and a guardrail chain that runs first.